RAM – Audit-Ready BCM Self-Assessment Manual

Policy Reference: L_0_21_Business_Continuity_Crisis
Framework Alignment: ISO 22301 | ISO 27001 | Internal Control | Risk & Compliance | IT Governance

---

1. Purpose of This Manual

This manual provides:

- A **structured, audit-defensible BCM maturity assessment methodology**
- Evidence requirements for internal & external audit
- Scoring logic with traceability
- Gap closure governance
- Reporting structure for Board & Audit Committee

It converts your BCM maturity tool into an **audit-compliant control framework**.

---

2. Governance & Oversight Structure

Role	Responsibility
Board Audit Committee	Oversight & annual review
CEO	Executive accountability
BCM Manager	Assessment coordination
Internal Audit	Independent validation
Risk & Compliance	Monitoring & reporting
Department Heads	Evidence submission

3. Assessment Frequency

- **Annual Full BCM Maturity Assessment**
- **Mid-Year Control Review**
- Post-major crisis reassessment

---

4. Control Domains & Evidence Matrix

DOMAIN 1: Governance & Leadership

Audit Objective:

Ensure BCM is formally embedded at strategic level.

Control	Evidence Required	Test Method
Board-approved BCM policy	Signed policy	Document review
Crisis Committee charter	TOR document	Governance check
Escalation matrix documented	Policy annex	Walkthrough
Annual review conducted	Meeting minutes	Audit confirmation

Scoring Logic (1–5):
1 = No formal governance
3 = Approved policy but limited oversight
5 = Board-integrated & audited annually

DOMAIN 2: Risk & BIA

Audit Objective:

Ensure impact-based prioritization exists.

Control	Evidence
Enterprise risk register	Risk system export
Documented BIA per function	Completed BIA forms
Defined RTO/RPO	Signed approval
Dependency mapping	IT/vendor matrix
Scenario testing records	Simulation reports

Audit Tests:

- Sample 3 critical functions
- Validate RTO vs actual simulation results
- Confirm update frequency

DOMAIN 3: IT Disaster Recovery

Audit Objective:

Validate technical resilience.

Control	Evidence
Backup logs	System report
DR site agreement	Contract copy
Penetration testing report	Security vendor report
Restore test documentation	Simulation log

Control Rating Criteria:

Level	Description
1	Manual backups only
3	Automated backups but untested
5	Tested recovery within RTO

DOMAIN 4: Facility & Operational Resilience

Control	Evidence
Fire drill reports	Drill logs
Evacuation maps	Posted plans
Vendor continuity clauses	Contract sample
Alternative workspace agreement	Lease/MOU

Audit Walkthrough:

- Inspect site physically
- Interview FM head
- Review last 12 months drill record

DOMAIN 5: Financial & Insurance Resilience

Control	Evidence
Business interruption insurance	Policy copy
Liquidity buffer policy	Treasury report
Crisis financial tracker	Finance records
Claim simulation	Test documentation

DOMAIN 6: Culture & Training

Control	Evidence
BCP training attendance	HR training log
Simulation participation	Drill attendance
Post-crisis review reports	Lessons learned report

Awareness communication	Email logs

5. Scoring Model

Each control scored 1–5.

Total Score = Sum of All Control Scores

Final Score	Maturity
0–30%	Reactive
31–50%	Basic
51–70%	Structured
71–85%	Integrated
86–100%	Predictive

6. Audit Testing Methodology

Internal Audit shall perform:

1 Document Review

Policies, logs, contracts, insurance.

2 Walkthrough Testing

Simulate incident notification flow.

3 Reperformance Testing

Request IT restore demo.

4 Interview Testing

CEO, BCM Manager, IT Head, FM Head.

5 Sample Testing

Random selection of:

- 3 departments
- 2 vendors
- 1 tenant emergency case

7. Audit Working Paper Template

Audit Ref: BCM-AUD-01
Year: ____

Control Tested Evidence Reviewed Findings Risk Rating Recommendation

8. Deficiency Classification

Level	Definition
Minor	Documentation gap
Moderate	Testing weakness
Major	Critical control missing
Severe	Recovery capability compromised

9. Management Action Plan Template

Finding Risk Level Root Cause Action Owner Deadline Status

10. Reporting Structure

A. Executive Summary (1 Page)

- Overall maturity %
- Top 5 risks
- Key deficiencies
- Budget implications

B. Heat Map Dashboard

Domain Score Status
Governance
Risk & BIA
IT
Facility
Financial
Culture

11. Red Flags for Audit Committee

- RTO not tested in last 12 months
- Insurance under-coverage
- No crisis simulation conducted
- DR not tested
- Dependency mapping missing
- Vendor continuity not validated

---

12. External Certification Readiness Checklist (ISO 22301)

☐ Policy approved
☐ BIA completed
☐ Risk assessment updated
☐ DR tested
☐ Training documented
☐ Management review conducted
☐ Internal audit completed

---

13. Three Lines of Defense Model

Line	Role
1st Line	Operations (BCM execution)
2nd Line	Risk & Compliance
3rd Line	Internal Audit

14. Control Documentation Index

Doc Code	Document
BCM-01	Risk Assessment
BCM-02	BIA
BCM-03	Crisis Declaration
BCM-06	DR Checklist
BCM-08	Post-Crisis Review
BCM-AUD-01	Audit Working Paper

15. Audit Conclusion Template

Based on procedures performed, RAM's Business Continuity Framework is assessed at **Maturity Level ___** with an overall effectiveness rating of ___%.
Key improvement areas include _____.
Management has committed to close identified gaps within ___ months.

Signed:
Head of Internal Audit
Date: ___

Next Level Options

We can now move to:

- 📊 Board-ready Resilience Radar Chart
- 📂 Full Internal Audit Program (step-by-step audit script)
- 📈 BCM Quantitative Risk Scoring Model
- 🏗️ Enterprise Resilience Integration with Enterprise Architecture
- 📦 Full RAM P&P Master Manual Consolidated Index

Tell me which direction to activate next.